ASSETTRUST / SECURITY ENGINEERING

v0.55 - Build reliability and release safety

Source audit, guarded npm lockfile bootstrap, Git-history and deployment-version integrity

RELEASE VERDICT: NO-GO - no customer data or commercial deployment

This checkpoint addresses a repeated release blocker without inventing a dependency lockfile. It adds a guarded npm bootstrap intended to run on a trusted, internet-connected Kali machine. It also fixes an outdated API health version and allows the supervised release runner to audit the original Git clone without bundling private history in the source ZIP.

Source changes verified

- --check performs a read-only dependency-manifest/lockfile review. --generate requires explicit opt-in, forbids production hosts, verifies trusted registry sources and refuses overwrites or changed workspace manifests.
- The API health endpoint reads its reported release from apps/api/package.json rather than retaining the stale 0.52.0 response.
- The supervised release workflow can scan the complete original Git clone through ASSETTRUST_HISTORY_REPO, while CI checks the new release tests ahead of npm ci.
- No SQL migration added or changed; existing identity, RLS, report-signing, evidence and malware-screening code remains in the checkpoint.

Executed offline evidence

Validation gate	Observed result
New v0.55 tests	16 / 16 PASS (npm behavior simulated)
All version suites v0.03 to v0.55	53 / 53 PASS
CI policy, architecture and offline smoke	PASS
TypeScript/TSX transpile-only syntax	104 files / 0 diagnostics
SQL migration source integrity	25 / 25 identical to v0.54
Current-source secret scan	2,317 files / 0 high-confidence matches

Remaining deployment blockers

The pass results above demonstrate offline code checks. They do not establish production security.

Unverified or blocked operations

- Real npm resolution did not complete here because registry access stalled; no authentic package-lock.json was created. A local npm ci attempt is blocked.
- Full API/web build is blocked by missing NestJS, Node type definitions and other dependencies. No npm audit vulnerability result is available.
- No live PostgreSQL RLS or cross-organization isolation test, no ClamAV daemon contract, no authenticated browser test and no two-server acceptance race was executed here.
- The original .git repository was not present in the ZIP, so the full historical credential scan remains unrun. The current-source scan is pattern-limited.
- HTTPS/TLS/SSH exposure, secure proxy controls, backup restoration, key custody, operator MFA, payment correctness and external penetration testing still require deployment evidence.

Exact next actions on trusted Kali Linux

1. Extract the v0.55 ZIP and confirm Node >=22.12. Do not modify your existing production database or encryption keys.

2. Run npm run verify:v55; then explicitly authorize the one-time lockfile creation: ASSETTRUST_V55_CREATE_LOCKFILE=YES npm run lockfile:generate:v55.

3. Review the generated package-lock.json and install-script requirements. Run npm run lockfile:check:v55, npm ci, npm audit --omit=dev --audit-level=high and npm run build.

4. Point ASSETTRUST_HISTORY_REPO at the original full clone; run npm run security:scan:v54 -- --repo an-absolute-repository-path and an independent full-history secret scan.

5. On an explicitly disposable local PostgreSQL database, run the supervised full suite with ClamAV, two-API, RLS and HTTP tests; inspect the generated evidence and pursue an independent security review.

Operator decision

Only 3 of 11 source-runner release prerequisites are currently present. Do not treat an offline version-test pass, a successful static scanner or this PDF as approval. The final security standard applies across AssetTrust, NETOLA, Farmer's Pride, Campus Live, BursarPro and future Codex/Claude implementations.

STATUS: HOLD PRODUCTION RELEASE